UNIDAD 4
Aseguramiento de la privacidad

Introducción a la Seguridad y Privacidad

Seguridad de la información

- Confidencialidad
- Integridad
- Disponibilidad

Uso masivo de datos personales

- Mayor exposición a amenazas
- Creciente dependencia de servicios en línea

Relevancia de los fraudes informáticos

- Impacto en usuarios y empresas
- Necesidad de medidas preventivas

4.1. Fraudes informáticos

Fraudes informáticos y robos de información

- Un **delito informático** es una infracción que usa medios electrónicos.
- Se centra en la confidencialidad, integridad y disponibilidad de los sistemas.
- **Difícil de probar y con mayor complejidad técnica** (rapidez de evolución).
- Convención de Budapest: define el fraude on-line y el perjuicio económico como : ”aquel acto deliberado e ilegítimo que causa un perjuicio patrimonial mediante un conjunto de procedimientos que evolucionan y se transforman vertiginosamente y que tienen la intención fraudulenta o delictiva de obtener ilegítimamente un beneficio económico”

Tipologías de delitos informáticos

- Acceso no autorizado a sistemas o redes (hacking malicioso).
- Robo de información confidencial (espionaje industrial, fugas de datos).
- Suplantación de identidad (phishing, spoofing).
- Sabotaje y denegación de servicios (DoS, DDoS).

Métodos de ciberdelincuencia (I)

- **Botnets**: redes de equipos infectados para spam, malware, ataques DDoS.
- **Spoofing** (suplantación):
  - **IP spoofing**: suplantar la ip para interceptar mensajes.
  - **Mail spoofing**: suplantar el remitente para engañar a destinatarios.
  - **GPS spoofing**: falsear la ubicación para despistar a la víctima
  - **ARP spoofing**: modificar tabla de arp.
  - **DNS spoofing**: falsificar tabla de dns.

Métodos de ciberdelincuencia (II)

- **SQL Injection**: introducir código SQL malicioso en formularios.
- **Rootkits**: herramientas maliciosas que modifican el sistema y escalan privilegios.
- **Ataques fuerza bruta**: prueba de contraseñas hasta descubrir la válida.
- **Ataques JavaScript**: inyección de scripts maliciosos en sitios web.

Fases en un ataque informático

- 1) Reconocimiento o **footprinting**: obtención de información del objetivo.
- 2) Escaneo o **fingerprinting**: puertos abiertos, direcciones MAC, etc.
- 3) **Intrusión**: ejecución de producto malware, pruebas de acceso.
- 4) **Robo** de información: alteración de privilegios en el sistema.
- 5) **Ocultamiento** del ataque: borrado de logs y huellas (túneles seguros).

Clasificación de atacantes

- Se pueden diferenciar por metodología, objeto e intención.

.

METODOLOGÍA

Hacker ético, cracker, grey hat, insider, phreaker, copyhacker, bucanero, scriptkiddie y lammer.

OBJETO

Sniffer, spammer, programador de malware e intruso.

INTENCIÓN

Instalador de bots, carder y ciberpunk.

CLASIFICACIÓN DE ATACANTES

Modo en que lo ejecuta
La actividad
Metodología

Clasificación de atacantes

Hacker	Posee conocimientos avanzados en informática y, especialmente, en los sistemas de cifrados y metodología de accesos a sistemas inseguros.
Hacker ético, white hat o sneaker	En estos términos, que entran en la definición de *hacker,* se le llama *hacker ético, de sombrero blanco* o, también, *sneaker,* a aquella persona atacante experta en seguridad que se especializa en comprobar posibles intrusiones al sistema o vulnerabilidades del mismo, pero con el ánimo de garantizar la seguridad. Un hacker ético trabaja en redes profesionales llamadas *red teams* o *tiger teams.*
Cracker o black hat	El hacker de sombrero negro o cracker alberga objetivos maliciosos, o para beneficio personal o para terceros. Intenta dañar los sistemas de información o roba información, mediante el borrado de ficheros e, incluso, cortando el acceso a sistemas o sitios web. Suele conocer lenguajes de programación destinados a proteger los sistemas de información y diseña programas para dañarlos.
Grey hat	Puede respetar las leyes o no. No entra en los sistemas con objetivos maliciosos o para beneficio personal, pero sí tiene el conocimiento para cometer delitos. Cuando detecta alguna brecha en sistemas, lo publica en comunidades hacker. Se trata, pues, de una persona a mitad de camino entre hacker ético y cracker.

CLASIFICACIÓN POR SU METODOLOGÍA DE TRABAJO

Hacker
Hacker ético
Cracker
Grey hat

Clasificación de atacantes

Insider	Puede poseer conocimientos de la organización, del sistema de información y de la propia información que maneja el sistema, y domina metodologías que pueden causar daños a la organización. Suele ser una persona que ha sido despedida, que conoce el entorno y las vulnerabilidades de seguridad y que ataca con ánimo de venganza.
Phreaker	Es especialista en tecnologías telefónicas e irrumpe en estas para obtener beneficios. Cuenta con excelentes conocimientos en telecomunicaciones y, a veces, ha trabajado en negocios de telefonía.
Copyhacker	Falsifica dispositivos hardware que copian el trabajo de otros atacantes para conocer las vulnerabilidades y, luego, los vende.
Bucanero	Comercia de manera ilegal en la red. No posee formación sustancial en informática, pero sí en áreas de negocios, donde aprovecha para cometer el delito.
Script kiddy	Persona sin experiencia que ejecuta scripts o programas de otros. Su huella se puede rastrear con facilidad debido a su escaso conocimiento en programación o en el manejo de los programas que usa.
Lammer	Persona con escaso nivel formativo que quiere convertirse en hacker. Ejecuta otras aplicaciones y no conoce los efectos de su ataque.

CLASIFICACIÓN POR SU METODOLOGÍA DE TRABAJO

Insider
Phreaker
Copyhacker
Bucanero
Script kiddy
Lammer

Clasificación por **objeto del ataque**

- **Sniffer**: interceptar y descifrar paquetes de datos en la red.
- **Spammer**: envío masivo de correos para colapsar buzones o difundir malware.
- **Programador de malware**: crea virus, gusanos, troyanos, etc.
- **Intruso**: experto encargado de un ataque concreto (robo de datos, sabotaje).

CLASIFICACIÓN POR EL OBJETO DEL ATAQUE

Sniffer
Spammer
Programador de malware
Intruso

Otros tipos de atacantes

- **Instalador de bots**: controla equipos de forma remota (botnets).
- **Carder**: roba datos de tarjetas de crédito (identidad de la víctima).
- **Ciberpunk**: altera sistemas para causar pérdidas de imagen o económicas.

OTROS TIPOS

Instalador de bots, Carder, Ciberpunk

4.2. Metodología en el ataque

Metodología en el ataque. Malware.

- **Malware**: "conjunto de herramientas informáticas cuyo objetivo es permitir actividades maliciosas en un sistema informático".
- **Virus**: Se adjunta a programas legítimos y requiere que el usuario los ejecute. Puede infectar y dañar archivos o sistemas.
- **Gusano**: Se propaga automáticamente a través de redes sin interacción del usuario, duplicándose en otros equipos.
- **Troyano**: Se disfraza de software inofensivo, pero abre vías de acceso remoto o instala otros programas maliciosos.
- **Spyware**: Recopila información del usuario (hábitos, contraseñas, datos personales) y la envía a un tercero sin consentimiento.

MALWARE (SOFTWARE MALICIOSO)

Virus
Gusano
Troyano
Spyware
Botnet
Scareware
Keylogger
Backdoors
SPAM

Metodología en el ataque. Malware.

- **Botnet**: Red de dispositivos infectados que el atacante controla de forma remota para enviar spam, lanzar ataques DDoS, etc.
- **Scareware**: Muestra falsas alertas de seguridad, generando miedo para que el usuario instale software fraudulento o pague por "soluciones".
- **Keylogger**: Registra todas las pulsaciones de teclado para capturar contraseñas y otros datos sensibles.
- **Backdoors**: Puertas traseras que permiten el acceso no autorizado a un sistema, eludiendo los mecanismos de seguridad.
- **Spam**: Correo electrónico no deseado y masivo que puede difundir publicidad engañosa, malware o estafas

MALWARE (SOFTWARE MALICIOSO)

Virus
Gusano
Troyano
Spyware
Botnet
Scareware
Keylogger
Backdoors
SPAM

2.py

Phishing

- **Phishing**: engaño vía correos falsos y sitios clonados para robar credenciales.
- **Smishing**: phishing por SMS, enlaces maliciosos en el móvil.
- **Pharming**: modificación de DNS o ficheros de resolución para redirigir a webs falsas.
- **Vishing**: llamadas que piden datos personales o bancarios de forma fraudulenta.

PHISING
Falsificación y suplantación de la interfaz de usuario de una web de confianza
Hoax/Bulo
Smishing
Pharming
Pharming local
Vishing
Scam/Estafa

Ataque DoS y DDoS

Dos: denegación del servicio

DDoS: denegación del servicio distribuido

Inundan la red de paquetes de datos anulando los recursos de red

Solución:

Asegurar contraseñas WiFi

Inspección de tráfico

Redireccionamiento permanente

Ataque DoS y DDoS

TIPOS DE ATAQUES DoS	
DoS por volumen	Se satura lo máximo posible el brazo de red en el que se encuentra un servidor para agotar su ancho de banda.
DoS por protocolo	Se satura la capacidad hardware, tanto los equipos como los dispositivos de seguridad de la red, con el objetivo de que dejen de ofrecer los servicios que prestan. Para ello, se usan técnicas de spoofin, ataques de paquetes o generación de syn floods. El famoso script Slowloris abre un gran número de conexiones simultáneas hacia un servidor que al final no usa, agotando el límite de sesiones paralelas que soporta el sistema.
DoS por aplicaciones	Se basa en el uso de herramientas que aprovechan los agujeros de seguridad en bases de datos y en aplicaciones con el fin de saturar un servicio, como pueden ser las herramientas exploit, los ataques javascript o los ataques de día cero (los *zero-day attacks*).

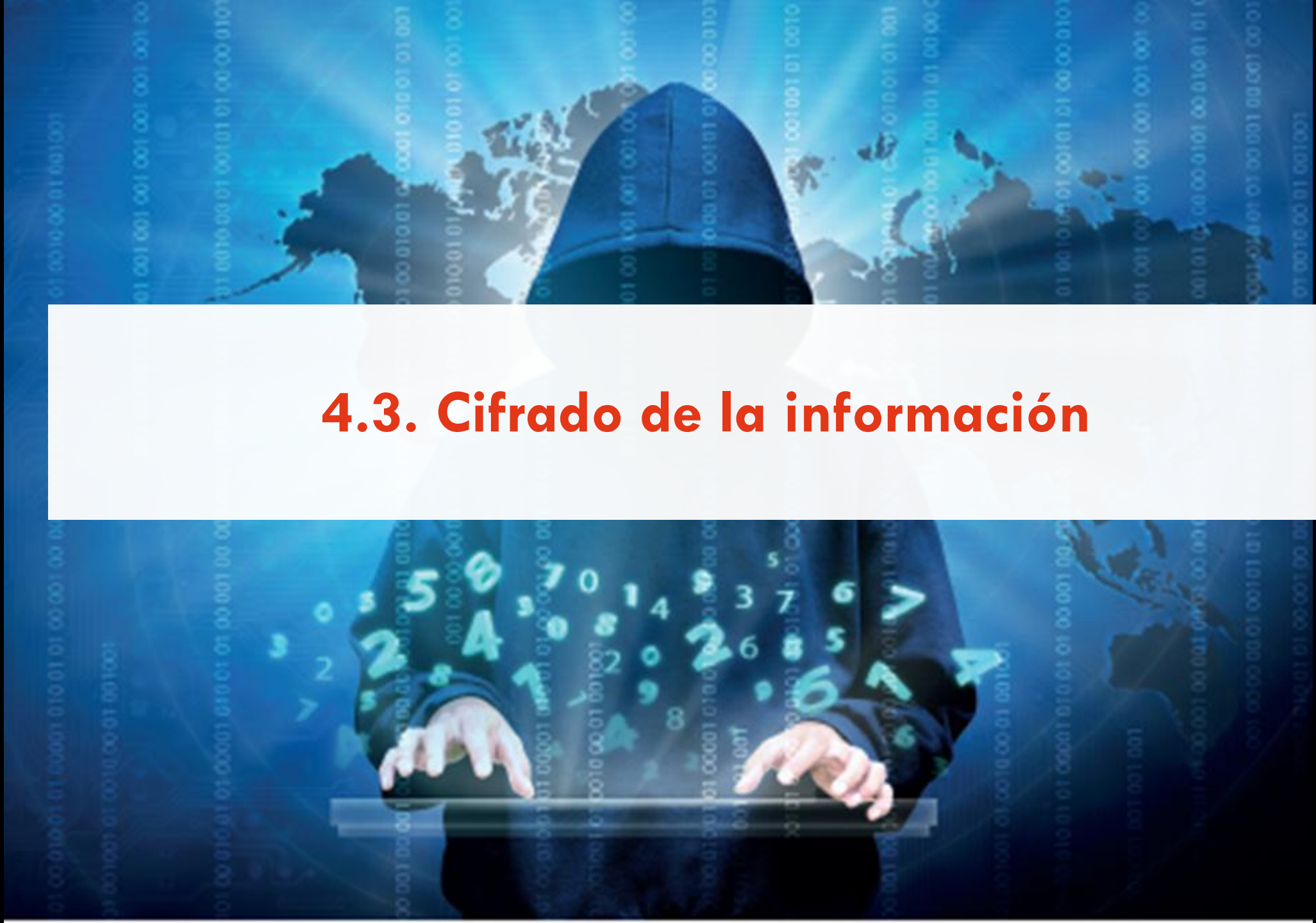
Aseguramiento de la privacidad.

La tendencia **Bring Your Ouwn Device** puede causar **brechas de seguridad** por donde se puede introducir software malicioso o filtrarse la información, debido a lo cual, se recomienda instalar software para monitorizar, asegurar y administrar dispositivos móviles (Mobile Device Management, MDM).

PELIGRO DEL BYOD

Los trabajadores pueden usar sus dispositivos para conectarse a Internet

4.3. Cifrado de la información



Introducción a la Criptografía

- **Criptografía**
  - Proceso criptográfico. → usa Algoritmo de cifrado con Clave de cifrado.
- **Criptoanálisis**: búsqueda de debilidades en métodos criptográficos.

CIFRADO DE LA INFORMACIÓN

Criptografía: Cifrar datos para conseguir máxima confidencialidad (mensajes comprensibles solo por autorizados)

Procesos criptográficos: Algoritmo de cifrado (operaciones matemáticas) + Clave de cifrado (SIMÉTRICA/PRIVADA o ASIMÉTRICA/PÚBLICA)

En la **criptografía** se pretende **transformar un mensaje** que se puede entender fácilmente en otro que no. Para ello, **se usan claves que solo los participantes en la comunicación conocen**. Ese mensaje cifrado se llama criptograma. Esta metodología se usa tanto en las comunicaciones de datos como en los procesos de autenticación de los usuarios.

Fases de la Criptografía digital.

Cifrado	Transforma el contenido del mensaje para que no pueda ser interpretado por terceros, consiguiendo la privacidad buscada.
Autenticación	Método para asegurar la identidad de alguien. Esta persona puede ser tanto la emisora de un mensaje como la receptora del mismo. Por lo tanto, un método para autenticarla puede ser el uso del propio cifrado. Si solo dos personas conocen la clave de transformación, el emisor puede demostrar ser quien dice ser con dicha clave de cifrado. Para ello, se usa o clave simétrica, es decir, tanto emisor como receptor conocen la clave empleada, o clave asimétrica, con un modo de autenticación conocido.
Firma digital	La firma garantiza la identidad en un mensaje. Para la firma digital, se usa una clave privada y otra clave pública. Lo que se cifra con la clave privada solo se puede descifrar con la pública. Con la clave privada, se cifra la identidad del emisor. Para garantizar que el emisor es quien dice ser a través de dicha clave privada, se hace necesario el envío de certificaciones de veracidad. Un usuario de la red puede certificar a otro ser quien dice ser, convirtiéndose en entidad certificadora.

Basada en la naturaleza de la clave. Criptografía simétrica (clave privada)

- Se **usa una misma clave para cifrar y descifrar.**
- Ejemplos: DES, AES.
- **Ventajas**: rapidez y facilidad de implementación.
- **Desventaja** principal: **intercambio seguro de la clave.**

CRIPTOGRAFÍA BASADA EN LA NATURALEZA DE LA CLAVE

Simétrica o privada: una única clave para cifrar y descifrar
DES, AES, RC4…
Asimétrica o pública: una clave para cifrar (no secreta) y otra para descifrar (secreta)
Mixta: mezcla propiedades de ambas
Algoritmo DES
Algoritmo AES

Basada en la naturaleza de la clave. Criptografía asimétrica (clave pública)

CRIPTOGRAFÍA BASADA EN LA NATURALEZA DE LA CLAVE

Simétrica o privada: una única clave para cifrar y descifrar
DES, AES, RC4…
Asimétrica o pública: una clave para cifrar (no secreta) y otra para descifrar (secreta)
Mixta: mezcla propiedades de ambas
Algoritmo DES
Algoritmo AES

- **Se emplean dos claves**: pública (cifrado) y privada (descifrado).
- Ejemplos: RSA.
- Beneficios: facilita el intercambio de claves, **autenticación del emisor.**
- Inconveniente: suele ser más **lenta** que la simétrica.

Basada en la naturaleza de la clave. Criptografía mixta y uso práctico

- Combina criptografía simétrica y asimétrica (cifrado híbrido).
- **La clave pública se usa para proteger la clave simétrica de sesión.**
- Ejemplo: Mensajes cifrados con AES y clave compartida via RSA.
- Mayor eficiencia y seguridad en las transacciones (e.g., HTTPS).

Basada en división de los datos.

- **Cifrado de flujo**
  - **Cifra bit a bit** los mensajes que llegan de forma continua.
  - Usa un flujo de clave y aplica XOR a cada bit del mensaje.
  - Adecuado cuando el tamaño del mensaje se desconoce de antemano.
- **Cifrado por bloques**
  - El mensaje se divide en **fragmentos** iguales antes de cifrarlos.
  - **Cada bloque se cifra de forma independiente** con la misma clave.
  - Se emplea en aplicaciones que procesan datos a bloques completos.
- Algoritmos destacados: ECB (Electronic CodeBook) - **WEP-RC4** cifrado inalámbrico inicial basado en RC4 (64 o 128 bits). Catalogado como inseguro, **sustituido por WPA y WPA2**.

Hash y funciones resumen

- Función hash: entrada de tamaño variable -> salida de longitud fija.
- Propiedades: irreversibilidad, resistencia a colisiones.
- Ejemplos: MD5 (ya débil), SHA (familia 1, 2, 3).
- Aplicaciones: almacenar contraseñas y verificación de integridad.

Práctica John the Ripper

CIFRADO DE CONTRASEÑAS
John the Ripper

Fuerza bruta
Ataque por diccionario

```
john --test
john --snow fich.txt
john --wordlist:dic.lst
fich.txt
```

```
Created directory: /home/administrador/.john
Benchmarking: descrypt, traditional crypt(3) [DES 128/128 SSE2-16]... DONE
Many salts:     4900K c/s real, 4979K c/s virtual
alt:  4405K c/s real, 4468K c/s virtual

sdicrypt, BSDI crypt(3) ("_J9..", 725 iterations) [DES 128/128 SSE2-16]... DONE
155899 c/s real, 159399 c/s virtual
66099 c/s real, 132729 c/s virtual

5crypt [MD5 32/64 X2]... DONE
real, 13932 c/s virtual

rypt ("$2a$05", 32 iterations) [Blowfish 32/64 X2]... DONE
real, 801 c/s virtual

[DES 128/128 SSE2-16]... DONE
/s real, 53702K c/s virtual

S, Kerberos AFS [DES 48/64 4K]... DONE
/s real, 413918 c/s virtual
s real, 1666K c/s virtual

ipcode [DES 128/128 SSE2-16]... DONE
s real, 4125K c/s virtual

ummy [N/A]... DONE
c/s real, 72339K c/s virtual

Benchmarking: crypt, generic crypt(3) [?/64]... DONE
Many salts:     340108 c/s real, 343544 c/s virtual
Only one salt:  357139 c/s real, 358573 c/s virtual
```